EXPERIMENT 12

Implementing Security Features and Governance / Administration Practices in Zoho Creator

Hotel Room Booking & Front Office Management — Security and Governance Use Case

Pavitha M
241401063

1. Aim

To plan and apply security features and governance and administration practices in the Hotel Room Booking & Front Office Management application built in Zoho Creator — covering sign-in security, user access, data permissions, safe scripting and integrations, controlled changes and auditing — so that guest data is protected and the application is managed in an orderly way.

The application stores personal details such as guest name, ID proof number, contact number, email address, permanent address and special requests, so access control and accountability are essential.

2. Procedure

Step 1: Identify what needs protection — The Room_Booking_Form and Room_Booking_Report were reviewed, and the sensitive data was listed: guest identity, ID proof number, contact details, permanent address, special requests and acceptance of the hotel policies.

Step 2: Plan account security — Sign-in protection was planned for all users: strong passwords, two-factor sign-in and single sign-on where the organisation uses it (Section 3.1).

Step 3: Design roles and permissions — Four user types — Administrator, Front Office Manager, Front desk and Guest — were defined, and a permission matrix was prepared following the principle of least privilege (Section 3.2).

Step 4: Define the access flow — The checks made when a user opens the application were drawn as a decision flow (Section 3.3).

Step 5: Secure scripts and connections — Safe Deluge practices were drafted, such as validating input and keeping connections limited to administrators, based on the earlier form validation and email workflow work (Section 3.4).

Step 6: Set up governance — Controlled changes through development, stage and production environments, audit review and periodic access reviews were planned (Section 3.5).

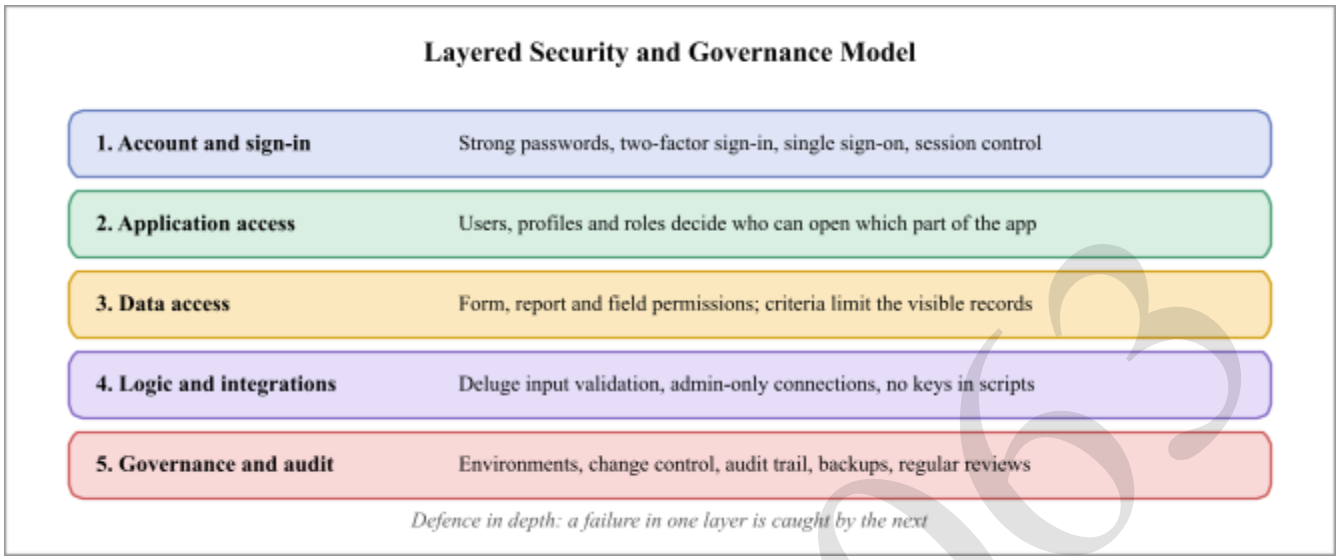
Step 7: Prepare the admin checklist — Threats and matching controls were tabulated, and an administration checklist was prepared for regular use (Sections 3.6 and 3.7).

Note: the settings are described as a planned configuration. No screenshots of the settings were captured for this record, so it does not claim that every option was turned on. Feature names and availability depend on the Zoho Creator plan and version and should be confirmed in the current documentation.

241401063

3. Output

3.1 Layered security and governance model



Security is arranged in five layers: account sign-in, application access, data access, logic and integrations, and governance with audit. A failure in one layer is caught by the next, which is the idea of defence in depth.

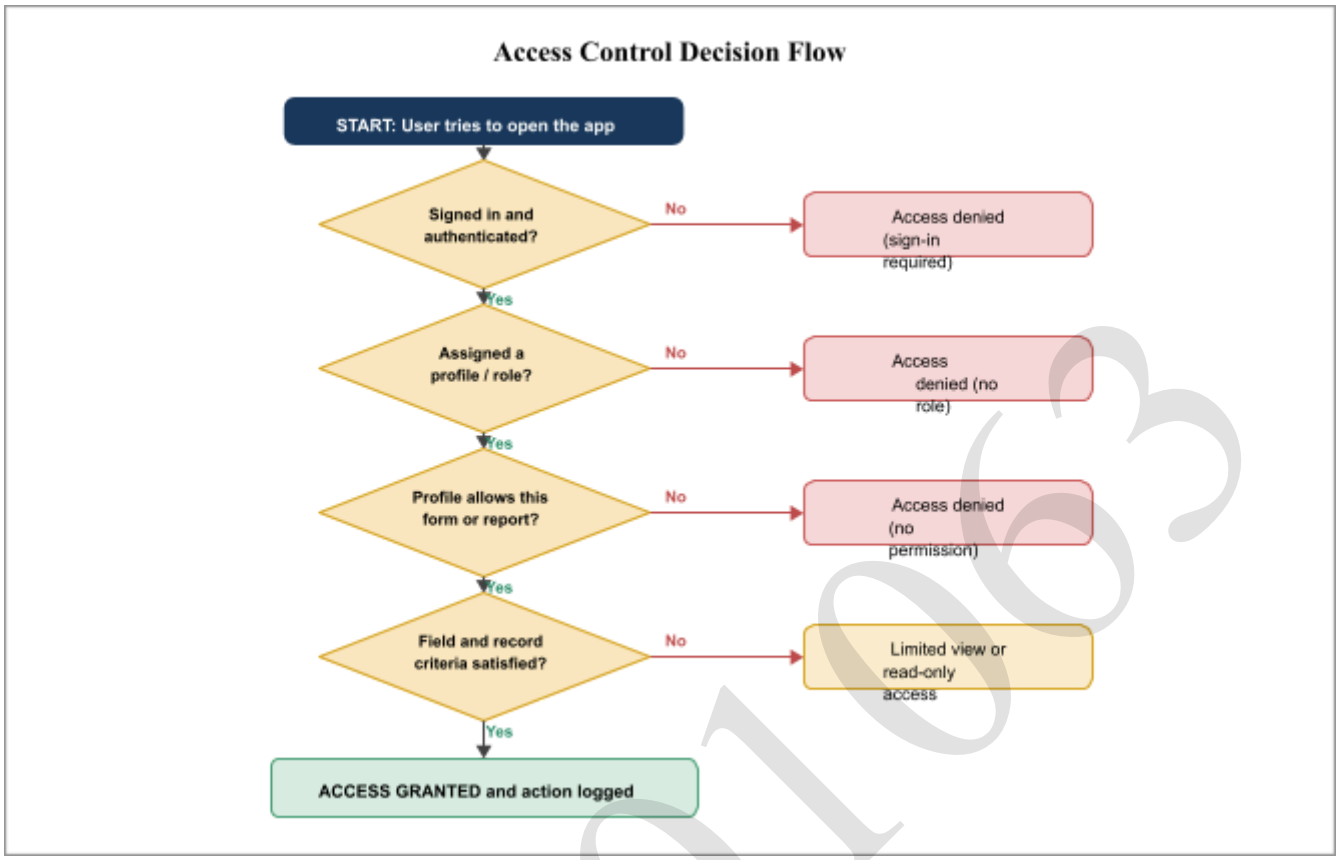
3.2 Proposed permission matrix

Each user type receives only the access needed for the job (least privilege). The matrix is a proposed design for the booking system.

Form / report	Administrator	Front Office Manager	Front desk	Guest
Room_Booking_Form (bookings)	View, edit, delete	View, edit	Create, view, edit	Create and view own request
Room_Booking_Report	Full access	View all	View today’s arrivals	View own booking
Room type and rate settings	Full access	View	View	No access
ID proof number, address	View, edit	View	Limited or hidden	Own entry only
Reports and exports	All reports, export	All reports, export	Daily arrival list only	No access
Users, connections, environments	Manage	No access	No access	No access

2140103

3.3 Access control decision flow



When a user tries to open the application, the system checks sign-in, then the assigned profile or role, then permission on the form or report, and finally field and record criteria. Failing any check denies or limits access, and granted actions are logged.

3.4 Secure scripting and connection practices (illustrative)

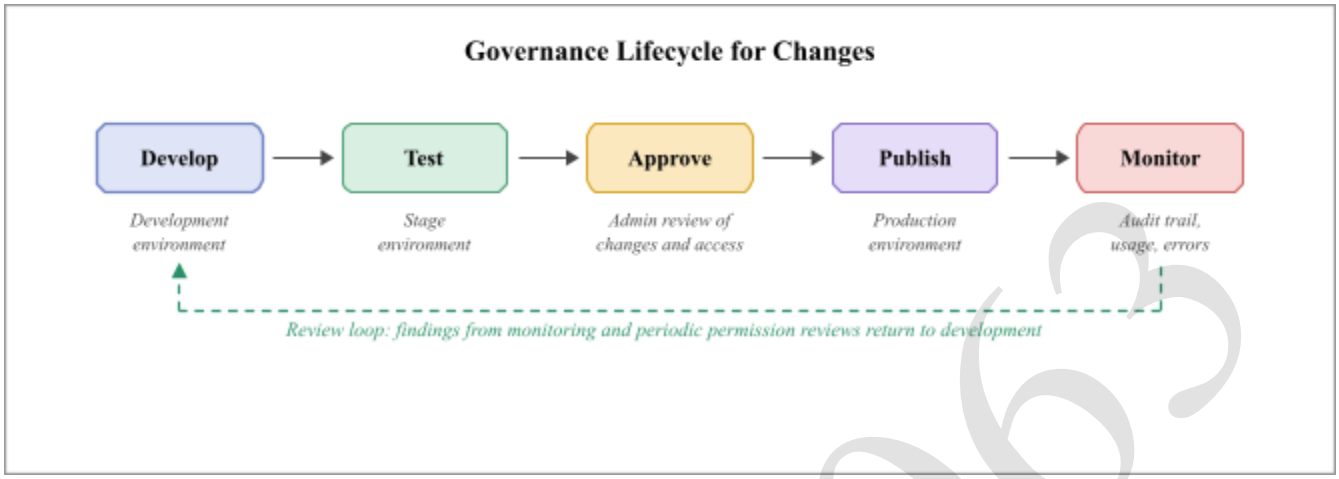
```
// On validate of the Room_Booking_Form
if(input.Agree_To_Hotel_Policies != true)
{
    alert "Please agree to the hotel policies before submitting.";
    cancel submit;
}
if(input.Number_Of_Guests < 1 || input.Number_Of_Guests > 6)
{
    alert "Number of guests must be between 1 and
    6."; cancel submit;
}
if(input.Check_In_Date < zoho.currentdate)
{
    alert "Check-In Date cannot be in the past.";
    cancel submit;
}

// Connection: use the stored link name, never a key written in the script
response = invokeurl
[
    url :sms_gateway_url
    type :POST
    parameters :payload.toString()
    connection :"hotel_sms_connection"
];
```

24140163

Input is validated on the server side of the form so wrong or missing data is rejected. Credentials stay in the connection, which is set to administrators only, and the gateway URL should be stored in a setting instead of being written inside the script. The code is illustrative; the connection and gateway named in it are examples and were not set up in this application.

3.5 Governance lifecycle for changes



Changes move from the development environment to the stage environment for testing, then to an administrator review, and only then to the production environment. Monitoring through the audit trail and periodic permission reviews feed improvements back into development.

3.6 Threats and matching controls

Threat	Example in this application	Control
Unauthorised access	A stranger or former staff member opens guest data.	Two-factor sign-in, remove users promptly, profile-based access.
Excess privilege	Front desk staff can delete or export all bookings.	Least privilege, separate permissions for delete and export.
Data leakage	The booking form or report is shared publicly by mistake.	Review sharing settings; limit public links to the booking request form only and never share the report.
Insecure scripts	Missing validation, or keys written inside Deluge code.	Validation on submit, connections instead of keys, code review.
Uncontrolled change	A live fix breaks booking or permissions.	Development, stage and production environments with approval.
No traceability	Nobody can tell who changed a booking.	Audit trail review and periodic log checks.

2414063

3.7 Administration checklist

Area	Administration practice	How often
Users	Add users with the correct profile; remove leavers the same day.	On every change
Permissions	Review profiles and exports against the permission matrix.	Every quarter
Sign-in	Confirm two-factor sign-in or single sign-on is enforced.	Every quarter
Connections	Check that connections are administrator-only and used only by needed apps.	Every quarter
Changes	Publish only after testing in the stage environment.	Every release
Audit	Look through the audit trail and usage metrics for unusual activity.	Monthly
Backup and recovery	Keep a recent backup and test that data can be restored.	As planned

4. Final Result

A layered security and governance plan was prepared for the Hotel Room Booking & Front Office Management application, covering sign-in protection, role-based access with a least-privilege permission matrix, an access-control decision flow, secure scripting and connection practices, controlled changes through environments, and regular auditing. Threats such as unauthorised access, excess privilege, data leakage, insecure scripts, uncontrolled change and lack of traceability were matched with controls, and an administration checklist was drawn up for regular use.

The exercise met its objective of designing security and governance for the application. The settings were not captured as screenshots, so the record presents them as a planned configuration to be confirmed in the live application.

2414010563